

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- Define the cloud service provider and cloud service customer roles precisely.
- Explain how customer responsibility scope changes across IaaS, PaaS, and SaaS.
- Define the cloud service broker, cloud auditor, and cloud carrier roles.
- Explain why independent auditing exists to fill a visibility gap customers cannot close themselves.
- Apply the catering-company analogy to explain shared responsibility to a non-technical stakeholder.

Introduction

When a cloud security incident occurs, one of the first and most consequential questions is 'who was responsible for the control that failed.' This guide builds the vocabulary needed to answer that question precisely, before an incident forces the answer under pressure.

Beyond the two most obvious roles, provider and customer, the Cloud Security Alliance and ISO recognize additional roles: the broker, the auditor, and the carrier. Each plays a distinct part in a real-world cloud deployment, and each carries its own security and governance considerations.

This guide grounds the roles framework in the lecture's retail-breach scenario and catering-company analogy, then extends it with practical due-diligence guidance you can apply directly to vendor and partner relationships.

Core Concepts Explained

Cloud service provider

Definition: The organization that builds and operates cloud infrastructure and makes it available to customers, responsible for the security of everything it manages.

Business relevance: The provider's obligations extend to physical data centre security, infrastructure resilience and isolation, and the security of platform services and APIs.

Cloud Security Practitioner relevance: You will evaluate provider obligations against their published shared-responsibility documentation and independent certifications, not against marketing claims.

Real-world example: A major cloud provider is responsible for the physical security of its data centres and the isolation integrity of its virtualization layer.

Risks or limitations: Assuming provider responsibility extends beyond its documented scope creates dangerous gaps in customer-side control coverage.

Cloud service customer

Definition: The organization or individual purchasing and using cloud services, responsible for everything within its agreed scope of management, which varies by service model.

Business relevance: Customer responsibility scope directly determines the security staffing and tooling investment an organization must make.

Cloud Security Practitioner relevance: You are expected to know exactly what your organization's scope of management is for each service in use, and to ensure controls exist for all of it.

Real-world example: In an IaaS arrangement, the customer manages operating systems, applications, data, and access policies; in SaaS, this narrows to data governance and identity management.

Risks or limitations: A customer that does not clearly define its own scope of management may leave gaps that neither party is actively covering.

Cloud service broker

Definition: An intermediary entity that manages the use, performance, and delivery of cloud services and negotiates relationships between providers and customers.

Business relevance: Brokers can simplify multi-provider governance through unified identity management, consolidated billing, and cross-provider service level monitoring.

Cloud Security Practitioner relevance: You must evaluate broker access to sensitive configuration and identity data with the same rigor applied to the primary provider relationship.

Real-world example: An enterprise consuming services from multiple cloud platforms engages a broker to provide a single governance and management interface across providers.

Risks or limitations: A broker relationship introduces a third party with access to potentially sensitive customer information, which regulated industries may need to subject to additional due diligence.

Cloud auditor

Definition: An independent third party that assesses cloud services for security, performance, and compliance with contractual and regulatory requirements.

Business relevance: Independent auditing fills the visibility gap that exists because customers usually cannot directly inspect provider infrastructure.

Cloud Security Practitioner relevance: You will rely on auditor-produced certifications (SOC 2, ISO 27001, FedRAMP) as a standardized basis for trust when direct inspection is not possible.

Real-world example: A customer reviews a provider's current SOC 2 Type II report as part of its annual vendor risk assessment rather than attempting to audit the provider's data centre directly.

Risks or limitations: Relying on outdated or scope-limited audit reports can create a false sense of assurance if the certification does not cover the specific service in use.

Cloud carrier

Definition: The intermediary that provides connectivity and transport of cloud services between providers and customers, typically network and telecommunications providers.

Business relevance: Confidentiality and integrity of data in transit depend partly on the security of the network path the carrier provides.

Cloud Security Practitioner relevance: For particularly sensitive workloads, you may need to evaluate or arrange dedicated private connectivity rather than relying solely on the public internet as the carrier.

Real-world example: An organization with highly sensitive workloads establishes a dedicated private connection to its cloud provider specifically to reduce exposure during data transit.

Practical Applications

These scenarios show the five-role framework applied to real governance decisions.

Mapping roles before a new deployment

Before onboarding a new cloud service, a security team explicitly identifies the provider, confirms whether a broker is involved, and notes what independent audit certifications exist for the service, documenting all of it in the vendor record.

Broker due diligence

When an enterprise engages a cloud service broker to unify identity management across three providers, the security team evaluates the broker's own access controls and contractual data-protection obligations as a distinct third-party risk, separate from the underlying providers.

Explaining shared responsibility to leadership

A security manager uses the catering-company analogy to explain to executive leadership why the organization still needs its own access governance program even after moving core systems to a well-regarded cloud provider.

Best Practices

- **Identify all five roles explicitly for every significant cloud relationship.** Provider, customer, broker, auditor, and carrier each carry distinct obligations that should be documented, not assumed.
- **Request current, scope-matched audit reports before trusting a provider's security claims.** Confirm that the certification you are relying on actually covers the specific service and region in use.
- Apply the same due-diligence rigor to broker relationships as to primary provider relationships, since brokers gain visibility into sensitive configuration and identity data.

Common Mistakes and Misconceptions

Misconception: Assuming only 'provider' and 'customer' roles exist in a cloud relationship.

Correct approach: Recognize that brokers, auditors, and carriers may all be present and each introduces its own security and governance considerations.

Misconception: Trusting a provider's marketing claims about security without independent verification.

Correct approach: Request and review current, scope-appropriate audit certifications (SOC 2, ISO 27001, FedRAMP) as the standardized basis for trust.

Misconception: Treating a broker as a simple convenience layer with no independent risk profile.

Correct approach: Evaluate broker access and contractual protections as a distinct third-party risk, especially in regulated industries.

Table: Cloud Roles Due-Diligence Reference

Use this table to identify what to verify for each role in a new or existing cloud relationship.

Role	What to verify
Provider	Published shared-responsibility documentation; current certifications
Customer (your org)	Documented scope of management for the specific service model in use
Broker	Access scope to identity/config data; contractual data-protection terms
Auditor	Certification currency, scope, and whether it covers the specific service/region
Carrier	Whether public internet or dedicated private connectivity is used for sensitive data

How to use this: Complete one row per active cloud relationship as part of your vendor risk register.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A retail company's customer database is breached after migration to a cloud provider. The provider states the infrastructure functioned as designed. Based on the lecture, what is the most likely explanation?

- A) A. The provider must be lying about its infrastructure.
- B) B. The breach occurred within the customer's zone of responsibility, such as a misconfiguration the customer controlled.
- C) C. Cloud providers are never responsible for any security outcome.
- D) D. The breach is unrelated to the roles and responsibilities framework.

Answer: B. The breach occurred within the customer's zone of responsibility, such as a misconfiguration the customer controlled.

Q2. Why does the cloud auditor role exist, according to the lecture?

- A) A. To replace the customer's own security team entirely.
- B) B. To provide independent assessment that fills the visibility gap customers face since they cannot directly inspect provider infrastructure.
- C) C. To negotiate pricing between providers and customers.
- D) D. To manage network connectivity between provider and customer.

Answer: B. To provide independent assessment that fills the visibility gap customers face since they cannot directly inspect provider infrastructure.

Q3. An enterprise engages a cloud service broker to unify billing and identity management across three cloud providers. What additional due-diligence consideration does this introduce?

- A) A. None; brokers do not require separate evaluation.
- B) B. The broker's own access to sensitive configuration and identity data must be evaluated as a distinct third-party risk.
- C) C. Broker relationships eliminate the need to evaluate the underlying providers.
- D) D. Brokers only affect billing and have no security implications.

Answer: B. The broker's own access to sensitive configuration and identity data must be evaluated as a distinct third-party risk.

Reflection Questions

1. Can you name all five cloud roles (provider, customer, broker, auditor, carrier) for a cloud service your organization uses?
2. Has your organization ever engaged a broker? If so, was its access and data-protection obligation formally evaluated?
3. How would you use the catering-company analogy in a conversation with a non-technical executive about cloud responsibility?
4. When did your organization last review a provider's current audit certification, and did you confirm it covers the specific service in use?

Key Takeaways

- The cloud service provider and cloud service customer are the two primary roles, but not the only ones relevant to security.
- Customer responsibility scope narrows as you move from IaaS toward SaaS, but never disappears entirely.
- The cloud auditor role exists specifically to fill the visibility gap customers face when they cannot directly inspect provider infrastructure.
- Cloud brokers introduce their own third-party risk profile that must be evaluated independently of the underlying provider.
- Cloud carriers matter for data-in-transit security, especially for organizations with highly sensitive workloads.

Recommended Next Actions

Put this lecture to work within the next seven days:

5. List every cloud role (provider, customer, broker, auditor, carrier) present in one significant cloud relationship your organization has.
6. Locate and review the most recent audit certification for one key cloud provider your organization uses.
7. If a broker is involved in any of your cloud relationships, confirm whether its access and data-protection terms have been formally reviewed.